AEGISAI ENTERPRISE EDITION

TECHNICAL DOCUMENTATION SUITE

ISO/IEC 42001:2023 AIMS Governance & Policies Manual

Corporate AI Policy, Impact Assessment (AIIA), Whistleblowing, Asset Inventory & Management Review

Platform Version:	**2.5.0 Enterprise Edition**
Compliance Scope:	**OWASP AISVS v1.0, ISO/IEC 42001:2023, Google Cloud Security**
License:	**Apache License 2.0 (Open Source)**

AegisAI Engineering Team

Confidentiality: Public / Open Source

AEGIS AI ASSURANCE PLATFORM

ISO/IEC 42001:2023 Artificial Intelligence Management System (AIMS) Governance, Policies & Compliance Manual

Version: 2.5.0 Enterprise (2026 Edition)

Standard Alignment: ISO/IEC 42001:2023 (Clauses 4–10 & Annex A.2–A.10) and OWASP AI-SVS v1.0

Classification: Mandatory Corporate AI Governance Manual, Policy Charter & Operational Evidence Register

Document ID: `AIMS-GOV-2026-001`

Approved By: Chief Information Security Officer (CISO), Chief AI Officer (CAIO) & Enterprise AI Governance Committee

---

1. Context of the Organization and Scope of the AIMS (Clauses 4.1, 4.2, 4.3, 4.4)

1.1 Understanding the Organization and its Context (`Clause 4.1`)

AegisAI operates as an **Autonomous Compliance & Security Assurance System (Recommendation and Decision-Support Engine)** designed for regulated enterprise environments (Financial Services, Retail, Healthcare, and Public Sector). Under ISO/IEC 42001:2023 `Clause 4.1`, the organization has formally determined all internal and external issues affecting its Artificial Intelligence Management System (AIMS):

1. **Organizational Role in the AI Value Chain:**
   - **AI System Developer & Integrator:** AegisAI designs, develops, and maintains the multi-normative Map-Reduce evaluation orchestrator (`server.ts`), deterministic scoring engine, and automated remediation synthesis pipeline (`remediatedArchitectureGenerator.ts`).
   - **AI Service Consumer (Cloud PaaS):** AegisAI consumes foundational models (`gemini-3.8-flash` , `gemini-3.1-flash-lite` , `gemini-3.7-flash`) hosted on **Google Cloud Vertex AI** under an enterprise data-zero-retention agreement.
2. **External Context & Regulatory Matrix:**
   - **Cybersecurity & Technical Assurance:** OWASP Artificial Intelligence Security Verification Standard (AI-SVS v1.0, Levels L1, L2, and L3).
   - **AI Governance & Management:** ISO/IEC 42001:2023 and NIST AI Risk Management Framework (AI RMF 1.0).
   - **Jurisdictional Legal Frameworks:** European Union Artificial Intelligence Act (Regulation (EU) 2024/1689 — High-Risk & Transparency obligations), Mexican Federal Law on Protection of Personal Data Held by Private Parties (*LFPDPPP* / INAI), and Mexican Federal Consumer Protection Law (*LFPC* / PROFECO Art. 76 Bis).
3. **Internal Context & Strategic Objectives:**
   - Enforce **100% deterministic factuality (`temperature: 0.0`)** with mandatory verbatim textual citations (`fuenteEvidencia` and `textoEvidencia`) to eliminate ungrounded compliance claims.
   - Maintain a strict **Human-in-the-Loop (HITL)** boundary: AegisAI generates technical audit reports and remediated architectures as decision-support artifacts; final certification sign-off requires human auditor authorization.

1.2 Understanding the Needs and Expectations of Interested Parties (`Clause 4.2`)

In compliance with `Clause 4.2`, the AIMS maintains a formal **Stakeholder Expectations & SLA Register** reviewed quarterly by the AI Governance Committee:

Interested Party	Role / Relationship	Core Expectations & Requirements	Binding AIMS SLA / Control Mechanism
Internal & External Cybersecurity Auditors	Primary System Operators	Zero hallucinations, verbatim documentary citations, reproducible scores, and non-repudiable audit trails.	`temperature: 0.0`, schema-constrained output, and immutable Firestore records (`allow delete: if false;`).
Audited Engineering Teams & System Owners	Assessed Subjects / Data Subjects	Fair evaluation, transparent rationale for failed controls, actionable remediation code, and right to contest inaccurate verdicts.	4D Remediation Recipes, Remediated Architecture Cookbook, and formal Verdict Appeal Channel (`ai-appeals@aegisai.enterprise`, **SLA: 5 business days**).
Corporate Executive Leadership (CISO / DPO / Legal)	Governance Sponsors	Full compliance with OWASP AI-SVS, ISO/IEC 42001, EU AI Act, and LFPDPPP; zero data leakage across tenants.	Multi-tenant domain isolation (`VITE_ALLOWED_DOMAINS`, Cloud IAP, Firestore tenant binding) and quarterly Management Reviews (`Clause 9.3`).
External Regulators (INAI, PROFECO, EU AI Office)	Supervisory Authorities	Demonstrable AI inventory, algorithmic impact assessments (AIIA), and 7-year forensic retention of compliance assessments.	7-year immutable retention in Cloud Firestore (`aegis-ai-db`) and exportable signed PDF/Markdown evidence packages.
Cloud & Model Providers (Google Cloud / Vertex AI)	Upstream Supply Chain	Compliance with Acceptable Use Policies, prevention of Denial-of-Wallet (DoW) abuse, and secure IAM authentication.	Dedicated `aegis-runner-sa` Service Account (ADC), sliding-window rate limiter (`C11.1`), and multi-turn crescendo detector (`C02.10`).

2. Leadership, Corporate AI Policy, and Governance Structure (Clauses 5.1, 5.2, 5.3, Annex A.2.1, A.2.3, A.3.2, A.3.3)

2.1 Leadership and Commitment (`Clause 5.1`)

Executive Management (CISO and CAIO) demonstrates formal leadership and accountability for the AIMS (`Clause 5.1`) through:

1. Direct chartering of the cross-functional **Enterprise AI Governance Committee** (comprising Cybersecurity, Legal/Privacy, AI Engineering, and Risk Management).
2. Ring-fenced annual budget allocation for Vertex AI inference quotas, automated security regression testing (`npm run test:security`), and third-party penetration testing.
3. Mandatory integration of AIMS compliance gates into the enterprise SDLC and Cloud Build deployment pipelines (`deploy_cloud_run.sh`), prohibiting production releases that fail OWASP AI-SVS Level 2 controls.

2.2 Corporate Artificial Intelligence Policy (`Clause 5.2` & `Annex A.2.1`)

> **POLICY STATEMENT (`POL-AIMS-001` — Approved by CISO & Executive Board):**

> *"All Artificial Intelligence systems developed, deployed, or operated within the organization—including the AegisAI Assurance Platform—shall operate under principles of **Deterministic Verifiability, Zero-Trust Security, Privacy by Design, Human Oversight, and Non-Retaliatory Ethical Escalation**."*

The Corporate AI Policy (`Clause 5.2` , `A.2.1`) establishes six binding mandates across the organization:

1. **Evidence-Only Adjudication:** No AI agent or evaluator may mark a security or governance control as passed (`Aprobado`) without extracting a verifiable, verbatim quote from the inspected architecture or live cloud manifest.
2. **Mandatory Human-in-the-Loop (HITL):** AegisAI operates strictly as an advisory assurance system. Automated verdicts cannot autonomously terminate employees, revoke production customer contracts, or execute destructive cloud mutations.
3. **Zero Unauthenticated Exposure:** Production AI workloads must be deployed behind **Cloud Identity-Aware Proxy (IAP)** and **Firebase Authentication** restricted to authorized corporate domains (`google.com` , `altostrat.com` , `coppel.com`).
4. **Strict Least Privilege:** Runtime service accounts (`aegis-runner-sa`) are restricted to `roles/aiplatform.user` and `roles/datastore.user` . Broad project-wide inspection roles (`roles/viewer` , `roles/editor` , `roles/owner`) are strictly prohibited on runtime identities.
5. **Cryptographic Supply Chain Integrity:** All normative snapshots (`owasp-aisvs-context.md` , `iso-42001-context.md`) and custom frameworks are verified at startup against SHA-256 digests in `config/frameworks/integrity-manifest.json` .
6. **Continuous Improvement Commitment:** The organization commits to continually improving the effectiveness of the AIMS through quantitative KPIs (`Clause 9.1`), semi-annual internal audits (`Clause 9.2`), and quarterly executive reviews (`Clause 9.3`).

2.3 Review of the AI Policy (`Annex A.2.3`)

In accordance with `Annex A.2.3` , the Corporate AI Policy (`POL-AIMS-001`) and all subordinate AIMS procedures undergo:

- **Scheduled Annual Review:** Conducted every Q4 (October) by the Enterprise AI Governance Committee to incorporate updates in ISO/IEC 42001, OWASP AI-SVS, and Google Cloud Vertex AI capabilities.
- **Event-Driven Ad-Hoc Review:** Triggered within **15 calendar days** upon any major regulatory enactment (e.g., EU AI Act delegated acts, LFPDPPP reforms), foundation model family migration (e.g., Gemini 2.5 to Gemini 3.8), or P1 security incident.
- **Version Control & Sign-Off Register:** Every policy revision is cryptographically committed to the corporate repository with semantic versioning, change rationale, and digital approval signatures from the CISO and Chief Legal Officer.

2.4 Confidential Whistleblowing and Ethical Escalation Channel (`Annex A.3.3`)

To satisfy `Annex A.3.3` (*Reporting of concerns*), AegisAI provides a permanent, confidential, and anonymous mechanism for employees, auditors, and third-party stakeholders to report ethical concerns, systemic bias, hallucination patterns, or safety bypasses:

- **Primary Reporting Channels:**

1. Direct UI Escalation Link embedded in the AegisAI Login screen (`Login.tsx`) and persistent application footer (`App.tsx`): `mailto:ai-ethics-whistleblower@aegisai.enterprise` .
2. Anonymous Zero-Knowledge Web Intake Portal: `https://ethics-hotline.aegisai.enterprise/report` (hosted independently by the Legal & Compliance Ombudsman).
    - **Non-Retaliation Guarantee:** Corporate Policy `POL-AIMS-003` strictly prohibits any form of retaliation, adverse employment action, or credential revocation against individuals who report AI safety or compliance concerns in good faith.
    - **Triage & Resolution SLA:** All `A.3.3` reports are acknowledged within **24 hours** by the AI Ethics Officer, investigated independently from the engineering team within **10 business days**, and reported in anonymized summary form during the quarterly Management Review (`Clause 9.3`).

---

3. Competence, Training, and Awareness Program (Clauses 7.2, 7.3)

3.1 Competence and Mandatory Certification Matrix (`Clause 7.2`)

Under `Clause 7.2`, personnel who design, operate, administer, or audit AegisAI must demonstrate verified technical and regulatory competence prior to being granted production access or `ADMIN_API_TOKEN` custody:

Role	Required Technical & Regulatory Competencies	Mandatory Certification / Assessment	Recertification Cadence
AI Platform Engineers & Maintainers	Secure LLM orchestration, OWASP Top 10 for LLM v2025, prompt injection defense (`C02.10`), TypeScript/Node.js security, and Google Cloud IAM least privilege.	**OWASP AI-SVS Secure Engineering Exam** (Passing score $\ge 85\%$) + Google Cloud Professional Cloud Security Engineer.	Annual (Every 12 months)
AIMS Auditors & Compliance Officers	ISO/IEC 42001:2023 clauses & Annex A auditing, algorithmic impact assessment (AIIA), evidence verification, and shared responsibility mapping.	**ISO/IEC 42001 Lead Auditor / Implementer Certification** + AegisAI Internal Calibration Workshop.	Annual (Every 12 months)
DevSecOps & Cloud Administrators	Cloud Run hardening, Cloud IAP, Serverless VPC Access, Secret Manager rotation, and Firestore Security Rules (`firestore.rules`).	**AegisAI DevSecOps Operational Readiness Assessment** + Incident Response Tabletop Drill.	Semi-Annual (Every 6 months)

Records of employee certifications, exam scores, and training completion timestamps are retained in the HR & Compliance Competence Register (`AIMS-REC-7.2`) and verified during internal AIMS audits.

3.2 Organizational Awareness Program (`Clause 7.3`)

In accordance with `Clause 7.3`, all authorized users of AegisAI are made aware of:

1. **The Corporate AI Policy (`POL-AIMS-001`) and Acceptable Use Policy (`A.9.1`)** directly upon login via the interactive governance notice in `Login.tsx` and the persistent AIMS footer in `App.tsx`.
2. **Their Personal Contribution to AIMS Effectiveness:** Mandatory onboarding modules covering proper evidence upload hygiene (sanitizing customer PII before uploading architecture diagrams) and mandatory human verification of AI-generated remediation code before production deployment.
3. **Implications of Non-Conformity:** Clear disciplinary and operational consequences for bypassing security guardrails, sharing API keys (`aisvs_*`), or misrepresenting advisory AI audit scores as unreviewed legal certifications.

---

4. AI Asset Inventory and Algorithmic Impact Assessment (Annex A.4.1, A.5.1, A.5.2, A.5.3)

4.1 Complete AI System, Model, Data, and Tooling Inventory (`Annex A.4.1`)

In compliance with `Annex A.4.1` (*Documentation of resources*), the organization maintains a live, versioned **AI Resource & Asset Register** (`AIMS-INV-A.4.1`) covering all models, datasets, frameworks, and cloud infrastructure components utilized by AegisAI:

Asset ID	Category	Component Name / Identifier	Provider & Hosting Region	Purpose & Criticality	Security & Integrity Control
`MOD-001`	Foundation LLM (Primary)	`gemini-3.8-flash`	Google Cloud Vertex AI (`us-central1`)	Primary Map-Reduce control evaluation & level classification (`High`).	ADC via `aegis-runner-sa`, `temperature: 0.0`, `responseLogprobs: false`, zero data retention.
`MOD-002`	Foundation LLM (Fallback 1)	`gemini-3.1-flash-lite`	Google Cloud Vertex AI (`us-central1`)	High-throughput fallback during quota spikes (`Medium`).	Automatic failover in `executeAIWithFallback` with 180s `AbortController` timeout.
`MOD-003`	Foundation LLM (Fallback 2)	`gemini-3.7-flash`	Google Cloud Vertex AI (`us-central1`)	Secondary resilient fallback (`Medium`).	Schema-constrained JSON generation (`buildBatchChaptersSchema`).
`DAT-001`	Normative Knowledge Base	`owasp-aisvs-context.md`	Immutable Container Image (`/app`)	Authoritative OWASP AI-SVS v1.0 control catalog (`Critical`).	Read-only filesystem (`chmod -R a-w /app`) + SHA-256 verification (`integrity-manifest.json`).
`DAT-002`	Normative Knowledge Base	`iso-42001-context.md`	Immutable Container Image (`/app`)	Authoritative ISO/IEC 42001:2023 clauses & Annex A catalog (`Critical`).	Read-only filesystem (`chmod -R a-w /app`) + SHA-256 verification (`integrity-manifest.json`).
`DAT-003`	Custom Legal Frameworks	`config/frameworks/*.json` & Firestore `custom_frameworks`	`/app/config/frameworks` & Firestore `nam5`	LFPDPPP, LFPC, EU AI Act & BYOF catalogs (`High`).	SHA-256 manifest check (`C01.4`) + Tenant domain pre-retrieval ACL filter (`C08.1`).
`INF-001`	Serverless Compute	Cloud Run Service `aegis-ai`	Google Cloud Run (`us-central1`)	Hosts Express API + React 19 SPA (`Critical`).	Non-root user `aegisuser`, Cloud IAP (`--no-allow-unauthenticated`), VPC private egress.
`INF-002`	Audit & State Store	Cloud Firestore `aegis-ai-db`	Google Cloud Firestore Native (`nam5`)	Stores immutable `audits`, `apiKeys`, `auditJobs`, `system_config` (`Critical`).	Cryptographic `firestore.rules` (308 unit tests), `allow delete: if false;`.
`INF-003`	Secrets Vault	Google Cloud Secret Manager	Google Cloud (`computeengine-506321`)	Stores `aegis-admin-token` (`Critical`).	Constant-time `crypto.timingSafeEqual` verification (`C05.3`).

4.2 Algorithmic Impact Assessment Process (`Annex A.5.1`)

Under `Annex A.5.1` (*Impact assessment process*), AegisAI mandates a structured **Algorithmic Impact Assessment (AIIA)** prior to the initial deployment of the platform and whenever a new foundation model, normative standard, or autonomous scanner capability is introduced:

1. **Trigger Conditions:** (a) Onboarding a new LLM family or external inference provider; (b) Adding or modifying a normative evaluation framework; (c) Modifying the scoring algorithm or level classification rules (`AUTO` L1/L2/L3); (d) Annual scheduled reassessment.
2. **Quantitative Risk Scoring Methodology:** Each potential failure mode is scored across **Severity ($S \in [1,5]$)**, **Likelihood ($L \in [1,5]$)**, and **Detectability ($D \in [1,5]$)** to compute the Risk Priority Number ($\text{RPN} = S \times L \times D$). Any failure mode with $\text{RPN} \ge 25$ or $S = 5$ requires mandatory engineering mitigation before release.
3. **Approval Gate:** Completed AIIAs must be signed off by the Technical Lead, the Data Protection Officer (DPO), and the CISO.

4.3 Assessment of Impact on Individuals and Groups (`Annex A.5.2`)

In accordance with `Annex A.5.2`, the organization has assessed how AegisAI's compliance verdicts impact individuals (software engineers, technical leads, security officers) and organizations (audited business units and their end customers):

Impact Dimension	Potential Adverse Scenario	Inherent Risk	Implemented Technical & Governance Safeguard	Residual Risk
False Positive Compliance ("Illusion of Security")	Model hallucinates compliance on an insecure architecture, leading to deployment of a vulnerable system that exposes end-user data.	Critical ($S=5, L=3$)	Strict `<regla_cero_evidencia_estricta>` prompt directive, `temperature: 0.0`, mandatory verbatim quote extraction (`textoEvidencia`), and automatic downgrade to `Falta Evidencia` if no quote is present.	Low ($S=5, L=1$)
Unfair Penalization of Engineering Teams (False Negative)	Model misinterprets valid architectural controls or penalizes a SaaS customer for cloud-provider hardware controls, delaying product launch or affecting performance reviews.	High ($S=3, L=3$)	Shared Responsibility Deduplication (`isInheritedFromPlatform`), interactive chapter remediation toggle in UI, and formal **Verdict Appeal & Human Review Workflow** (`ai-appeals@aegisai.enterprise`).	Low ($S=2, L=1$)
Privacy & Confidentiality Exposure	Uploaded architecture PDFs or source code contain employee emails, internal IPs, or proprietary trade secrets.	High ($S=4, L=2$)	In-memory file parsing (`multer.memoryStorage()`), zero training retention on Vertex AI, tenant-scoped Firestore rules (`ownerUid`/`tenantDomain`), and log masking (`redactSensitiveStrings`).	Low ($S=2, L=1$)

Right to Contest & Human Review Procedure (`A.5.2`): Any Technical Lead or System Owner may contest an AegisAI verdict by clicking **"Impugnar Dictamen / Revisión Humana (A.5.2)"** in the application footer (`mailto:ai-appeals@aegisai.enterprise`) or annotating the chapter in `AuditReportView`. A certified Lead Auditor reviews the contested control against the raw documentary evidence within **5 business days** and issues a binding human addendum.

4.4 Documentation and Retention of Impact Assessments (`Annex A.5.3`)

Under `Annex A.5.3`, all Algorithmic Impact Assessments (AIIAs), audit reports (`audits/{auditId}`), normative decomposition logs, and human appeal addenda are preserved under a strict **7-Year Forensic Retention Policy**:

- **Immutability Enforcement:** Cloud Firestore security rules (`firestore.rules`) enforce `allow delete: if false;` across `/audits/{auditId}` , `/custom_frameworks/{fwId}` , and `/auditJobs/{jobId}` .
- **Cryptographic Lineage:** Every stored audit report records the exact timestamp (`date`), evaluated standards (`standardsBreakdown`), platform profile (`techPlatform`), owner identity (`ownerUid` , `ownerEmail` , `tenantDomain`),

and normative snapshot SHA-256 baseline (`integrity-manifest.json`).

---

5. Performance Evaluation, Internal Audit, and Management Review (Clauses 9.1, 9.2, 9.3)

5.1 Monitoring, Measurement, Analysis, and Evaluation (`Clause 9.1` & OWASP `C08.4`)

In compliance with `Clause 9.1` and OWASP AI-SVS `C08.4` , AegisAI continuously measures and exposes real-time AIMS & RAG grounding telemetry via the administrative endpoint `GET /api/admin/aims-telemetry` (authenticated via `x-admin-token`):

KPI / Metric ID	Metric Name	Target SLO / Threshold	Measurement Method in `server.ts`	Alert / Escalation Trigger
`KPI-AIMS-01`	**Citation Grounding Rate (Faithfulness)**	$\ge 95.0\%$ of approved controls	Ratio of `Aprobado` controls containing a non-empty verbatim quote (`textoEvidencia.length >= 12`) to total `Aprobado` controls (`recordAimsEvaluationMetrics`).	Structured `WARNING` alert in Cloud Logging if `< 95%`; triggers prompt calibration review.
`KPI-AIMS-02`	**Inference Determinism Index**	100.0% at `temperature: 0.0`	Verified on every evaluation call and via `GET /api/security/posture`.	Immediate deployment block if default temperature $\neq 0.0$.
`KPI-AIMS-03`	**End-to-End Evaluation Latency (P95)**	$\le 180,000\text{ ms}$ per batch	Tracked per Map-Reduce batch with `AbortController` timeout and model fallback telemetry.	Automatic failover to `gemini-3.1-flash-lite` on timeout or HTTP 429/503.
`KPI-AIMS-04`	**Active Defense Detection Rate**	100% of known injection/DoW signatures	Real-time counters for `promptInjectionBlocks` (`C02.10`), `rateLimitRejections` (`C11.1`), and `ssrfBlocks` (`C04.3`).	High-severity `[AEGIS_SECURITY_ALERT]` event dispatched to Cloud Logging (`C12.2`).

5.2 Internal AIMS Audit Program (`Clause 9.2`)

In accordance with `Clause 9.2` , the organization executes a formal **Semi-Annual Internal AIMS Audit Program** (every April and October):

1. **Auditor Independence & Objectivity:** Internal audits are conducted by certified ISO/IEC 42001 Lead Auditors from the Corporate Risk & Compliance Assurance division who have **no operational or reporting responsibility** for AegisAI engineering.
2. **Audit Scope & Methodology:**
   - **Self-Assurance Meta-Audit:** Running AegisAI's own technical documentation bundle (`Originaldocs.zip`) and live GCP project (`computeengine-506321`) through the multi-standard OWASP AI-SVS + ISO/IEC 42001 evaluator.
   - **Automated Security Verification:** Executing `npm run test:security` , `firestore.rules.test.ts` (308 assertions), and `GET /api/security/posture` integrity checks.
   - **Governance Records Inspection:** Sampling training records (`Clause 7.2`), AIIA registers (`A.5.3`), whistleblowing logs (`A.3.3`), and appeal resolutions (`A.5.2`).
3. **Non-Conformity Tracking (CAPA):** Any identified non-conformity (`Fallido` or `Falta Evidencia`) is logged as a Corrective and Preventive Action (CAPA) with a mandatory root-cause analysis and remediation deadline (**15 days for High risk, 30 days for Medium risk**).

5.3 Management Review (`Clause 9.3`)

Under `Clause 9.3`, Executive Management (CISO, CAIO, DPO, and Engineering Directors) convenes a formal **Quarterly AIMS Management Review** (Q1, Q2, Q3, Q4).

- **Mandatory Review Inputs (`Clause 9.3.2`):**

1. Status of actions from previous Management Reviews.
2. Changes in external/internal context (`Clause 4.1`), regulatory frameworks (EU AI Act, LFPDPPP, OWASP AI-SVS), and stakeholder expectations (`Clause 4.2`).
3. Quantitative telemetry from `GET /api/admin/aims-telemetry` (`KPI-AIMS-01` through `KPI-AIMS-04`), security incident logs (`[AEGIS_SECURITY_ALERT]`), and internal audit results (`Clause 9.2`).
4. Summary of confidential ethical escalations (`A.3.3`) and verdict appeals (`A.5.2`).
    - **Mandatory Review Outputs (`Clause 9.3.3`):** Signed Executive Minutes (`AIMS-MIN-9.3-YYYY-QX`) recording formal decisions on continuous improvement opportunities, model upgrades, resource/quota adjustments, and policy revisions.

---

6. Responsible Use, Acceptable Use Policy (AUP), and Post-Deployment Monitoring (Annex A.9.1, A.9.2)

6.1 Responsible Use and Acceptable Use Policy (`Annex A.9.1`)

To satisfy `Annex A.9.1` (*Use of AI systems*), all operators and API consumers of AegisAI are bound by the **AegisAI Acceptable Use Policy (`AUP-AIMS-002`)**, displayed prior to authentication (`Login.tsx`) and enforced technically at runtime:

1. **Intended Authorized Use:** AegisAI is authorized exclusively for defensive cybersecurity auditing, architectural gap analysis, regulatory compliance verification, and defensive remediation planning for enterprise software systems.
2. **Strictly Prohibited Uses:**
    - Using AegisAI as a sole, unreviewed automated decision-maker for legal certification, regulatory filing, or employee performance termination without human auditor sign-off.
    - Submitting adversarial prompt injection payloads, multi-turn crescendo jailbreaks, or excessive concurrent requests intended to exhaust cloud inference budgets (automatically blocked and logged by `inspectPromptAndTrackSession` and `acquireAntiDoWQuota`).
    - Uploading classified state secrets or unredacted production customer databases containing raw payment card data (PCI-DSS) or unmasked health records (PHI).

6.2 Processes for Responsible AI Use and Continuous Post-Deployment Monitoring (`Annex A.9.2`)

In compliance with `Annex A.9.2`, AegisAI implements continuous operational governance throughout the system lifecycle:

1. **Automated Startup & Runtime Integrity Verification:** Every container boot executes `verifyNormativeSnapshotsIntegrity()` against `config/frameworks/integrity-manifest.json` (`C01.4`), ensuring that the normative baselines used in production have not drifted or been tampered with.
2. **Continuous Grounding & Drift Monitoring:** Every audit execution feeds `recordAimsEvaluationMetrics()` (`Clause 9.1` / `C08.4`), tracking citation faithfulness and verdict distributions across all evaluated standards to detect model drift following upstream Vertex AI model updates.
3. **Quarterly Normative Re-Baselining:** Every quarter, the AI Governance Committee reviews the bundled normative files (`owasp-aisvs-context.md`, `iso-42001-context.md`, `fw-eu-aiact-2026.json`, `fw-lfpdppp-mex-2026.json`, `fw-lfpc-mex-2026.json`), updates the SHA-256 integrity manifest, and executes regression benchmarks before promoting changes to production.